

ISO 27001 - Reporte de Gestión de Incidente de Seguridad – Vulnerabilidad de inyección SQL en DVWA

1. Introducción

Este informe documenta la identificación y explotación de una vulnerabilidad de inyección SQL en la aplicación Damn Vulnerable Web Application (DVWA). La prueba se realizó en un entorno controlado con fines académicos, para demostrar cómo un atacante puede comprometer la seguridad de una aplicación web mediante entradas manipuladas.

2. Descripción del incidente

Durante la evaluación de seguridad de DVWA, se detectó una vulnerabilidad en el módulo SQL Injection ya que permite la ejecución de consultas SQL maliciosas a través del campo de entrada "User ID". Esta vulnerabilidad compromete la integridad y confidencialidad de la información almacenada en la base de datos, exponiendo datos sensibles de usuarios.

3. Proceso de reproducción

1. Acceso a DVWA en la VM Debian mediante `http://localhost/DVWA`.
2. Inicio de sesión con credenciales por defecto:
Usuario: admin
Contraseña: password
3. Configuración del nivel de seguridad en Low.

DVWA Security

Security Level

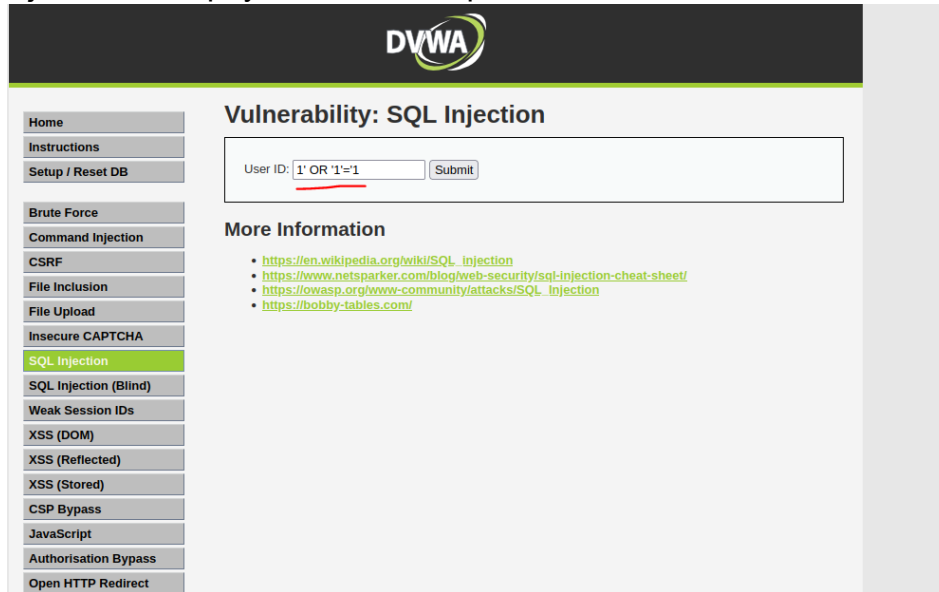
Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.

Low

4. Ejecución del payload en el campo “User ID”: 1' OR '1'='1



The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The top header features the DVWA logo. On the left, a sidebar lists various vulnerability categories: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection (highlighted), SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript, Authorisation Bypass, and Open HTTP Redirect. The main content area is titled 'Vulnerability: SQL Injection'. It contains a form with a 'User ID:' label, a text input field containing the payload '1' OR '1'='1', and a 'Submit' button. Below the form, there is a section titled 'More Information' with a list of links: https://en.wikipedia.org/wiki/SQL_injection, <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>, https://lowasp.org/www-community/attacks/SQL_injection, and <https://bobby-tables.com/>.

5. Resultado: listado completo de usuarios extraído de la base de datos.

4. Evidencia del ataque

La aplicación devolvió información de múltiples usuarios:



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

Authorisation Bypass

Open HTTP Redirect

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

Esto confirma que la consulta fue alterada y se extrajeron datos sin autorización.

5. Impacto del incidente

La explotación de esta vulnerabilidad podría permitir a un atacante:

- Acceder y extraer información confidencial de la base de datos.
- Modificar o eliminar datos sensibles.
- Comprometer la disponibilidad y confiabilidad de los servicios de la aplicación.

Este incidente representa un riesgo crítico para la confidencialidad, integridad y disponibilidad de la información.

6. Recomendaciones

- 1. Validación de entradas:** Implementar consultas parametrizadas y sanitización de datos.
- 2. Pruebas de penetración periódicas:** Auditorías regulares para detectar vulnerabilidades.
- 3. Concientización y capacitación:** Formación en prácticas seguras de desarrollo.
- 4. Principio de mínimo privilegio:** Configurar cuentas de base de datos con permisos limitados.

7. Conclusión

La identificación y explotación de la vulnerabilidad de inyección SQL en DVWA demuestra la importancia de aplicar controles de seguridad proactivos en el desarrollo y mantenimiento de aplicaciones web. La implementación de medidas correctivas y preventivas es esencial para proteger los activos críticos y garantizar la continuidad del negocio.